

Overview of Computer security

1.1. Computer Security Concepts

1.2. Computer Security, Information Security, Network Security

1.3. Threats, Attacks and Assets

1.4. Security Requirements

1.5. Security Design Principles

1.6. Attack Surfaces and Attack Trees

1.7. Computer Security Strategy

Overview of Computer security

- Computer security is a branch of information technology that deals with protecting computer systems, networks, and sensitive information from unauthorized access, theft, damage, or destruction. In today's interconnected world, computer security has become an essential aspect of personal and business operations.
- Computer security can be achieved through a combination of physical, technical, and administrative controls. Physical controls include measures such as security cameras, access controls, and biometric authentication. Technical controls include firewalls, intrusion detection and prevention systems, and encryption. Administrative controls include policies and procedures for access control, incident management, and risk management.
- Computer security refers to the protection of computer systems and networks from unauthorized access, theft, damage, and other forms of cyber attacks. It encompasses a wide range of technologies, practices, and policies designed to safeguard the confidentiality, integrity, and availability of computer systems and data.
- Computer security threats can be caused by hackers, viruses, malware, and other forms of malicious software. These threats can compromise sensitive information, cause damage to computer systems, and disrupt business operations.

Overview of Computer security

Computer security measures must be **regularly updated** to keep pace with evolving threats. Organizations can implement **security policies and training programs** to educate employees on **best practices for computer security**. Additionally, conducting regular **security assessments and penetration testing** can help identify vulnerabilities and address potential risks before they are exploited.

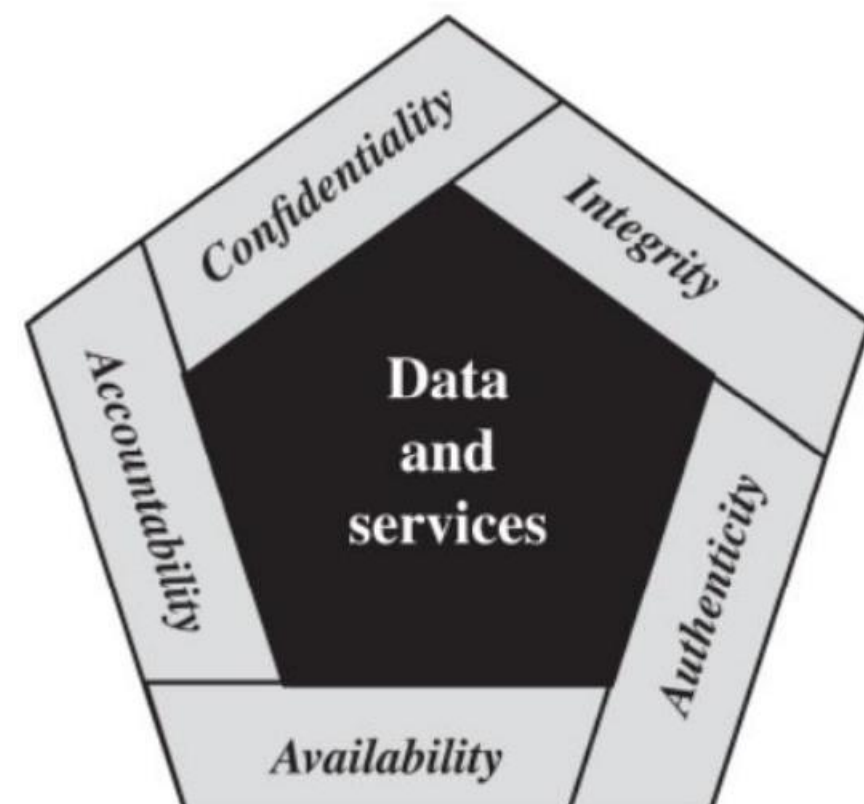
Computer Security, Information Security, Network Security

- **Computer Security:** A company might use **antivirus software** to protect their computer systems from malware and other malicious software. They might also implement password policies to ensure that only **authorized personnel can access the computers**.
- **Information Security:** A hospital might have policies and procedures in place to protect patient information, such as ensuring that medical records are only **accessed by authorized personnel** and that sensitive **information is encrypted**.
- **Network Security:** A bank might use a firewall to protect their **network from unauthorized access**, as well as **encryption protocols to protect sensitive data** transmitted over the network, such as customer account information.

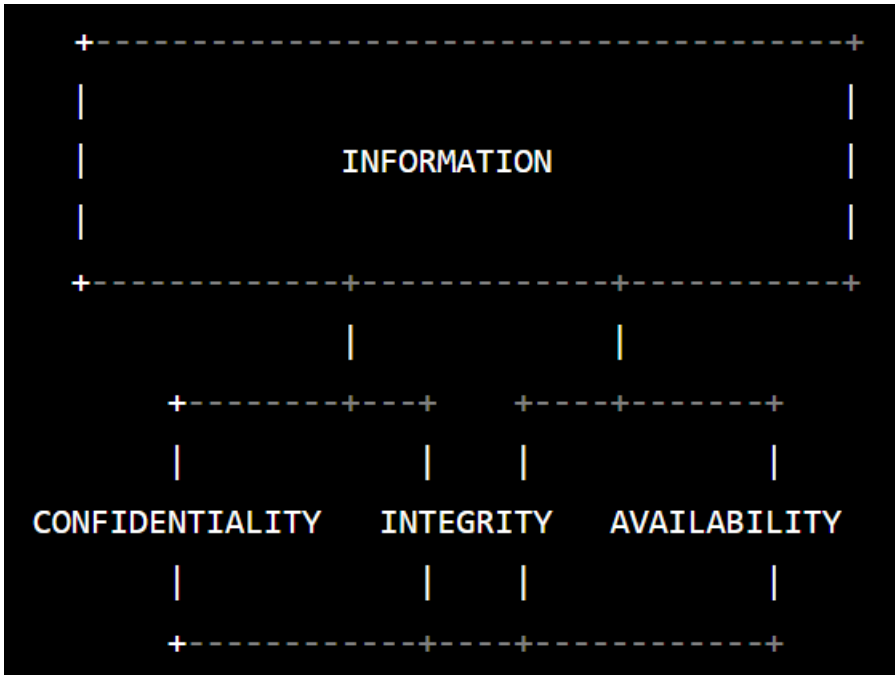
Overview of Computer security

- The three main goals of computer security are:
 - **Confidentiality**: ensuring that sensitive information is only accessible to authorized individuals.
 - **Integrity**: ensuring that data is accurate and has not been tampered with or modified without authorization.
 - **Availability**: ensuring that computer systems and data are accessible to authorized users when needed.
- Computer security involves a variety of measures to achieve these goals, including:
 - **Authorization**: Determining what actions users are allowed to perform.
 - **Non-repudiation**: Ensuring that a user cannot deny having performed an action.
 - **Auditing**: Monitoring and recording user activity to identify potential security incidents or policy violations.
 - **Encryption**: Encryption is the process of encoding data in such a way that only authorized parties can read it.
 - **Firewalls**: A firewall is a network security device that monitors and filters network traffic to prevent unauthorized access.
 - **Anti-malware**: Anti-malware software is designed to detect and remove malicious software such as viruses, worms, and trojans from computer systems.
 - **Intrusion Detection and Prevention Systems**: These systems monitor network traffic and detect and prevent unauthorized access attempts.
 - **Security policies and procedures**: These are guidelines and protocols that define how data and systems should be accessed, used, and protected.
 - **Disaster recovery and business continuity**: These are plans and procedures that ensure that critical data and systems can be restored in the event of a disaster.

Overview of Computer security



CIA Triad



The CIA Triad		
What Is the CIA?		
Confidentiality	Integrity	Availability
The information is safe from accidental or intentional disclosure.	The information is safe from accidental or intentional modification or alteration.	The information is available to authorized users when needed.
Example		
I send you a message, and no one else knows what that message is.	I send you a message, and you receive exactly what I sent you (without any modification)	I send you a message, and you are able to receive it.
What's The Purpose of the CIA?		
Data is not disclosed	Data is not tampered	Data is available
How Can You Achieve the CIA?		
e.g., Encryption	e.g., Hashing, Digital signatures	e.g., Backups, redundant systems
Opposite of CIA		
Disclosure	Alteration	Destruction

Overview of Computer security

CIA	Risk	Control
Confidentiality	• The risk of privacy lose • Unauthorized disclosure	1- Encryption 2-Authentication 3- Access Control
Integrity	Modified data by an unauthorized source	1- Access Control 2- Cryptography
Availability	Unavailable of resources & information	1- Backup Solutions 2- Fault tolerance 3- High- Availability

Major challenges of computer security

- **Evolving Threat Landscape:** Cyber threats are **constantly evolving**, and attackers are **constantly developing new techniques** to exploit vulnerabilities in computer systems and networks. Keeping up with these threats and adapting security measures accordingly can be a significant challenge.
- **Complexity:** Computer systems and networks can be **extremely complex**, with multiple layers of hardware and software that need to be secured. This complexity can make it **difficult to identify and mitigate vulnerabilities**.
- **Insider Threats:** Insider threats, such as employees with access to sensitive data who **intentionally or unintentionally cause security breaches**, can be a significant challenge for computer security.
- **Human Error:** Human error, such as **weak passwords** or **misconfiguration of security settings**, can also lead to security breaches. **Educating users** about best practices for computer security can help mitigate this risk.
- **Compliance:** Organizations may need to **comply with various regulations and standards** related to computer security, such as HIPAA. Ensuring compliance with these requirements can be a significant challenge.
- **Cost:** Implementing effective computer security measures can be costly, and **smaller organizations may not have the resources to invest** in the latest security technologies or hire dedicated security personnel.
- Overall, these challenges highlight the importance of implementing a comprehensive computer security strategy that incorporates a range of protection mechanisms and addresses the specific risks and vulnerabilities of an organization's computer systems and data.

Health Insurance Portability and Accountability Act

Security Requirements

- Security requirements are a set of specifications and measures that organizations put in place to protect their information systems, data, and assets from unauthorized access, use, disclosure, disruption, modification, or destruction. These requirements can be specific to an organization's needs, industry, or regulatory environment.
- **Access Controls:** Access controls ensure that only authorized users have access to sensitive data and systems. This can include password policies, two-factor authentication, and permissions-based access control.
- **Encryption:** Encryption is the process of converting information into a secret code to protect it from unauthorized access. Organizations may use encryption to protect data in transit and at rest, including email communications, file transfers, and databases.
- **Firewalls:** Firewalls are hardware or software-based security systems that monitor and control incoming and outgoing network traffic. They can help prevent unauthorized access to an organization's systems and data.
- **Anti-Malware:** Anti-malware software, such as antivirus and anti-spyware programs, can help detect and prevent malicious software from infecting an organization's systems and networks.
- **Vulnerability Scanning and Penetration Testing:** Vulnerability scanning and penetration testing are security measures that help identify potential weaknesses in an organization's systems and networks. They involve scanning systems for known vulnerabilities and conducting simulated attacks to identify potential vulnerabilities.
- **Disaster Recovery and Business Continuity:** Disaster recovery and business continuity planning are essential security requirements for ensuring that an organization's systems can be quickly restored in the event of a security breach or other disaster.

Security Design Principles

- **Defense in Depth:** This principle involves using **multiple layers of security controls to protect systems and data**. This includes physical security controls, access controls, network segmentation, encryption, and monitoring.
- **Least Privilege:** This principle involves **granting users and processes the minimum level of access** necessary to perform their tasks. This reduces the risk of unauthorized access or misuse of data.
- **Separation of Duties:** This principle involves **separating critical tasks and assigning them to different individuals or groups**. This reduces the risk of fraud or other types of insider threats.
- **Fail-Safe Defaults:** This principle involves configuring systems and networks **to be secure by default**. This reduces the risk of misconfiguration or human error.
- **Secure Communications:** This principle involves using secure protocols and encryption to protect data in transit. This includes protocols such as **HTTPS, SSH, and VPNs**.
- **Auditability:** This principle involves **logging and monitoring system activity to detect and investigate security incidents**. This includes monitoring **access logs, system logs, and network traffic**.
- **Resilience:** This principle involves designing systems to be able to **withstand attacks and recover quickly** from security incidents. This includes disaster recovery planning, data backups, and redundancy measures.
- **Security by Design:** This principle involves integrating **security considerations into the design and development of systems** and applications from the outset. This can help prevent security vulnerabilities and reduce the risk of cyberattacks.
- Overall, these security design principles provide a framework for organizations to create secure systems and networks. By following these principles, organizations can **reduce the risk of cyberattacks and ensure the confidentiality, integrity, and availability of their information systems and data**.

Threats, Attacks, and Assets

- **Threats:** A threat is any potential danger that could exploit a vulnerability to breach security and cause harm to an asset. There are several types of threats, including
 - **Malware:** This is software that is designed to harm or disrupt computer systems. Examples include viruses, worms, and Trojan horses.
 - **Phishing:** This is a type of social engineering attack that uses email or other means to trick people into revealing sensitive information, such as login credentials or financial information.
 - **Denial of Service (DoS):** This is an attack that floods a network or website with traffic to make it unavailable to users.
 - **Physical threats:** These are threats to physical assets, such as theft, vandalism, or natural disasters.
- **Attacks:** An attack is a deliberate attempt to exploit a vulnerability in a system or network to gain unauthorized access, steal data, or cause harm. Some examples of attacks include:
 - **Brute force attacks:** These are attacks that try to guess passwords or encryption keys by trying every possible combination until the correct one is found.
 - **Man-in-the-middle attacks:** These are attacks where an attacker intercepts communications between two parties to eavesdrop or modify the messages.
 - **SQL injection attacks:** These are attacks where an attacker inserts malicious code into a SQL database query to gain access to sensitive data.

Threats, Attacks, and Assets

- **Assets:** An asset is anything of value that needs to be protected from threats and attacks
 - **Customer data:** This includes personal information such as names, addresses, and payment information. Retailers, financial institutions, and healthcare providers are examples of organizations that must protect customer data.
 - **Intellectual property:** This includes proprietary software code, patents, trademarks, and trade secrets. Companies in the technology, manufacturing, and pharmaceutical industries must protect their intellectual property.
 - **Critical infrastructure:** This includes systems that are essential to the functioning of society, such as power grids, water treatment.
 - **Hardware:** This includes servers, workstations, and mobile devices.
 - **Software:** This includes operating systems, applications, and databases.
 - **Networks:** This includes the infrastructure used to connect devices and systems, such as routers, switches, and firewalls.
 - **People:** This includes employees, contractors, and customers who have access to systems and data.

Computer Security Strategy

- **Risk assessment:** Begin by identifying potential risks to your organization's computer systems and data. This could include risks such as malware, phishing attacks, data breaches, and unauthorized access to systems.
- **Develop a security policy:** Create a comprehensive security policy that outlines your organization's security standards, including password requirements, access controls, and incident response procedures.
- **Employee training:** Educate your employees about the importance of computer security and provide training on how to recognize and respond to potential security threats.
- **Regular updates:** Keep all software, operating systems, and security systems up-to-date with the latest security patches and updates.
- **Access controls:** Implement access controls, including user authentication and authorization, to ensure that only authorized users have access to sensitive data and systems.
- **Backup and recovery plan:** Develop a backup and recovery plan to ensure that critical data is backed up regularly and can be quickly recovered in the event of a security breach or system failure.
- **Continuous monitoring:** Regularly monitor your systems for suspicious activity and potential security threats.
- **Incident response plan:** Develop an incident response plan that outlines how your organization will respond to security incidents, including who will be involved, what steps will be taken, and how communication will be handled.

Attack Surfaces and Attack Trees

- An attack surface refers to the **set of all possible points where an attacker could attempt to gain unauthorized access to a system or network**. This includes not only **physical access points** like doors and windows, but also software vulnerabilities and other potential weaknesses that could be exploited by an attacker.
- An attack tree, on the other hand, **is a hierarchical model** that depicts the **various steps an attacker might take in order to achieve a particular goal**. Each node in the tree represents a particular attack vector, and the branches represent the different options available to the attacker at each step.
- By creating an attack tree, **security professionals can identify the most likely attack paths and focus their efforts on securing those specific points**. This can help organizations to prioritize their security efforts and allocate resources more effectively.

Attack Surfaces and Attack Trees

Let's consider a **web application that allows users to upload and share files** with each other. The attack surface of this application might include:

- **Input validation vulnerabilities:** The application **might not adequately validate the type and size of files** that users upload, leaving it open to attacks such as **buffer overflows or SQL injection**.
- **Authentication vulnerabilities:** The application might have **weak authentication mechanisms**, such as **easily guessable passwords or no password policy** in place.
- **Network vulnerabilities:** The application **might not be configured securely**, leaving it open to attacks such as man-in-the-middle attacks or denial-of-service attacks.

An attack tree for this application might look like this:

Level 1: Gain access to the application

Branch 1: Exploit input validation vulnerabilities

Branch 2: Exploit authentication vulnerabilities

Branch 3: Exploit network vulnerabilities

Level 2: Upload malicious file

Branch 1: Upload a file containing malware

Branch 2: Upload a file containing a backdoor

Level 3: Compromise the system

Branch 1: Execute the malware

Branch 2: Use the backdoor to gain remote access to the system